记一次渗透测试#信息和搜集

（c段+站点归属）

目　录

一、　漏洞挖掘.....1

二、　亿点总结.....4

文档摘要

文档编号	
文档名称	记一次渗透测试#信息和搜集（c 段+站点归属）
文档版本	V1.0
文档作者	Ha1Lan
参与编写	
文档审核	
文档分类标识	
文档状态	☐草案 ☐修订中 ☑试用 ☐正式发布 ☐废止
首次编写日期	
文档属性	☐内部保密 ☑内部公开 ☐外部公开
发布范围	

一、 漏洞挖掘

首先，查看漏洞收集范围

域名

KYSRC接受漏洞业务范围：

1.金山云网站：*.ksyun.com

2.金山云App（以最新版为准）：

应用名称	下载链接	备注
金山云App	http://www.ksyun.com/	官网最下方右侧
金山企业云App	http://e.ksyun.com /download_outerindex.htm	
金山企业云盘App	https://pan.ksyun.com /downloadclient#/loading	

备注：

1.不在上述范围内的站点或IP一经确认属于金山云，奖励方案同样适用；

2.金山云上用户的漏洞，不在收录范围内；

3.金山云投资的公司以及与金山云无关的漏洞，不在收录范围内；

4.不属于金山云企业资产范围的漏洞，将转交到漏洞盒子互联网漏洞流程处理。

其次，收集资产。

这里我用的是 teemo（使用方法自行研究）

各API申请指引(非必要)

其中部分接口需要API Key，如果有相应账号，可以在config.py中进行配置，**没有也不影响程序的使用。**

Google CSE(自定义搜索引擎):

- 创建自定义的搜索引擎（CSE）https://cse.google.com/cse/all
- 申请API Key: https://developers.google.com/custom-search/json-api/v1/overview

Bing API:

- https://azure.microsoft.com/zh-cn/try/cognitive-services/my-apis/
- https://api.cognitive.microsoft.com/bing/v5.0/search
- https://docs.microsoft.com/en-us/azure/cognitive-services/bing-web-search/quick-start

Fofa:

- 需要购买会员

Shodan:

- 登陆后页面右上角“show API key”

基本使用

运行环境：python 2.7.*

Teemo.py -d ksyun.com

```
251 webps.ks3-cn-beijing.ksyun.com
252 workorder.ksyun.com
253 wps-account-avatar.ks3-cn-beijing.ksyun.com
254 wps-account-qr.ks3-cn-beijing.ksyun.com
255 wpsmail-cloud.ks3-cn-beijing.ksyun.com
256 www.ksyun.com
257 www.ksyun_com
258 xaxx.ks3-cn-beijing.ksyun.com
259 xiaomi-miui-ota-3rdrom.ks3-cn-beijing.ksyun.com
260 xiaomi-miui-ota-update.ks3-cn-beijing.ksyun.com
261 xmcfs.kss.ksyun.com
262 yl.ksyun.com
263 zookcloud.kss.ksyun.com
264 120.92.15.0/24
265 120.92.71.43
266 10.69.56.96
267 185.199.111.153
268 58.254.155.0/29
```

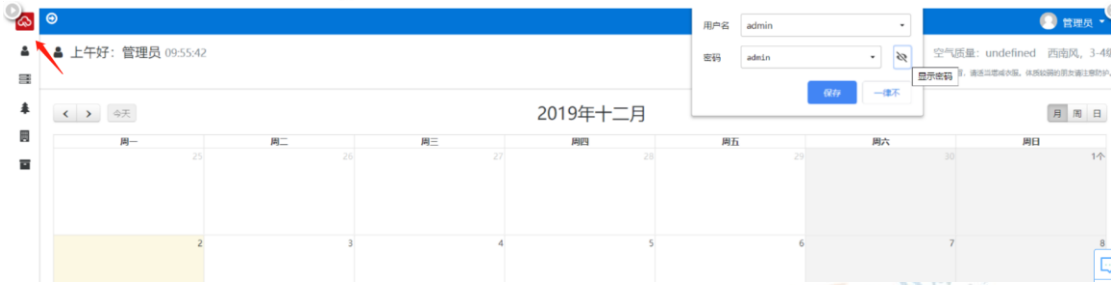
它会把搜索到的子域名+ip 记录下来（其他工具大多也有此功能）。

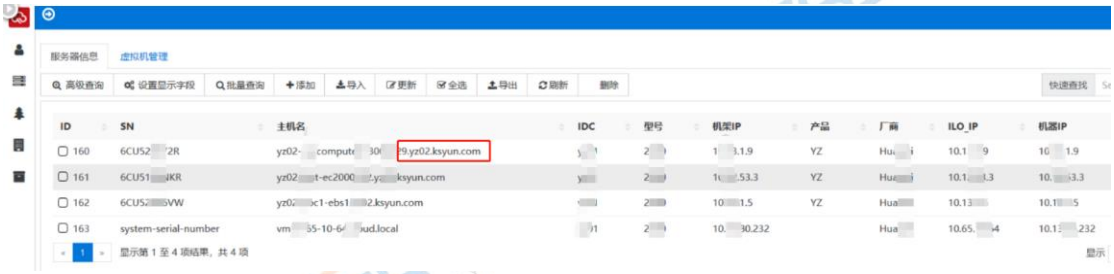
然后，我们这次的重点在于 c 段
在某 c 段中，发现这样的一个页面

并没有金山云 logo 等标识
抱着试试的态度，admin/admin

发现这确实是金山云的资产

// 通过 logo，以及页面某些特殊的标识





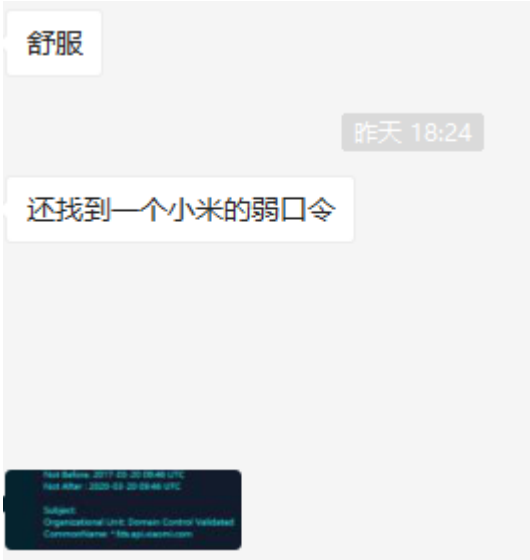
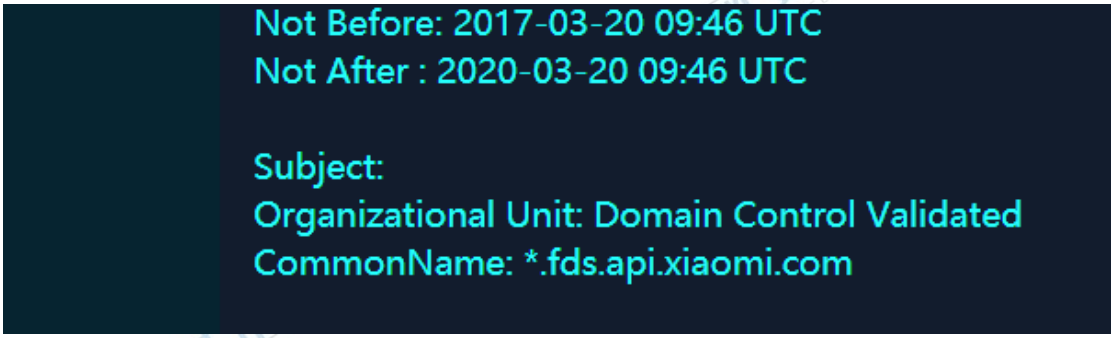
最后提交漏洞，等待漏洞审核…

不得不说，金山云的漏洞审核是真的快。

恭喜发财，可以买点水果吃了。

二、 亿点总结

写到最后，我之前也曾随便看过金山云的资产，但是一无所获，原因是"常见"的域名无从下手，也没有去看 c 段，就开始暗示自己金山云有点难挖，实际上是自己懒，只是浅度的尝试。所以挖洞一定要有耐心，而且也要细心。也许一不小心就挖到了（我这个是在一个比较严肃的场景下挖到的，嘿嘿），也许一不小心就挖到其他 src 的漏洞了，谁说的清呢。



// 可以通过查看 ssl 证书来证明归属（特殊情况除外）